

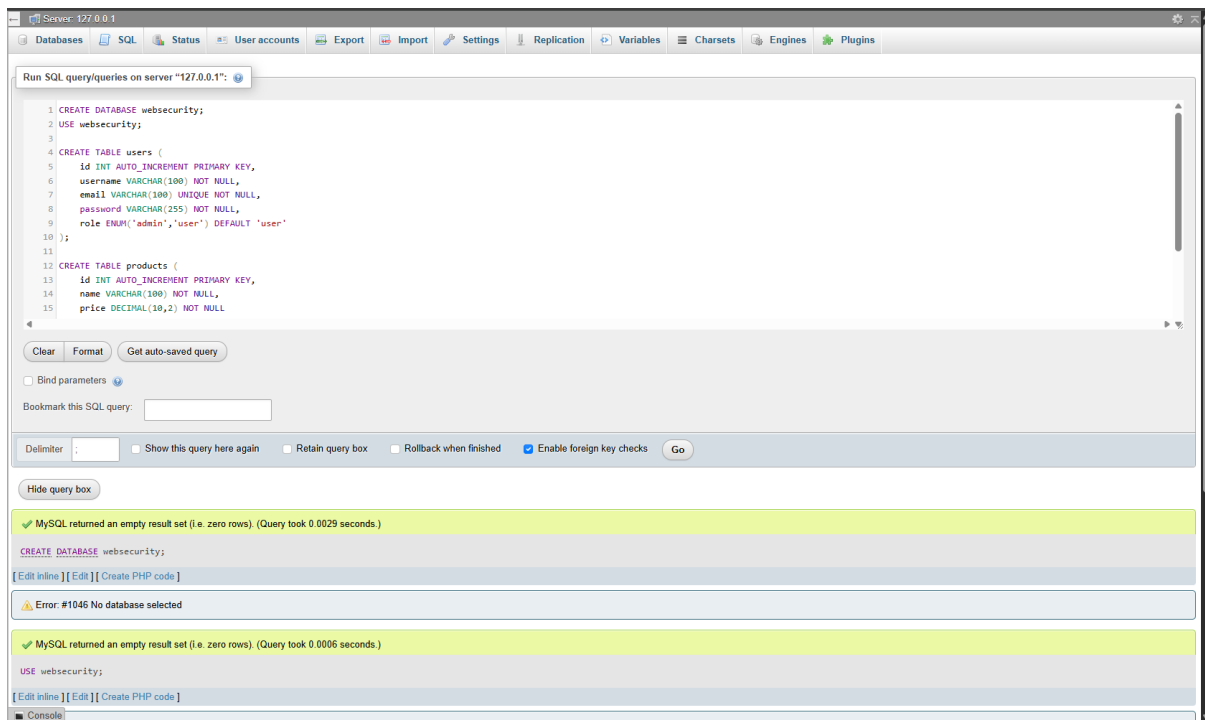
20CYS403 – WEB APPLICATION SECURITY

SECURE WEB APPLICATION DEVELOPMENT

Ponvedica M S

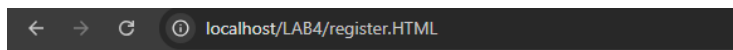
CB.SC.U4CYS23034

First, we are creating the database and the table name users and products



```
1 CREATE DATABASE websecurity;
2 USE websecurity;
3
4 CREATE TABLE users (
5   id INT AUTO_INCREMENT PRIMARY KEY,
6   username VARCHAR(100) NOT NULL,
7   email VARCHAR(100) UNIQUE NOT NULL,
8   password VARCHAR(255) NOT NULL,
9   role ENUM('admin','user') DEFAULT 'user'
10 );
11
12 CREATE TABLE products (
13   id INT AUTO_INCREMENT PRIMARY KEY,
14   name VARCHAR(100) NOT NULL,
15   price DECIMAL(10,2) NOT NULL
16 );
```

1. Create a registration page [username, email, password]. Hash the password using bcrypt before storing it in the database.



User Registration

Username:

Email:

Password:

Role:

[Login](#)

First, we are registering as user. And then we are storing the password in hash using bcrypt in the database.

Showing rows 0 - 0 (1 total, Query took 0.0006 seconds.)

```
SELECT * FROM `users`
```

☐ Profiling [\[Edit inline \]](#) [\[Edit \]](#) [\[Explain SQL \]](#) [\[Create PHP code \]](#) [\[Refresh \]](#)

☐ Show all | Number of rows: 25 | Filter rows: Search this table

Extra options

	id	username	email	password	role
☐ Edit ☐ Copy ☐ Delete	1	vedica	vedica@gmail.com	\$2y\$10\$9EEFFleXy7OThfWdPS.aeqYXlrrXdod0LVNOo5ooy...	user

☐ Check all | With selected: ☐ Edit ☐ Copy ☐ Delete ☐ Export

☐ Show all | Number of rows: 25 | Filter rows: Search this table

localhost / 127.0.0.1 | phpMyAdmin x localhost/LAB4/register.php x +

localhost/LAB4/register.php

Registration Successful

[Login](#)

2. Create a login page and try to login with the registered user. Verify the entered password against the stored hash and create a session on success.

localhost / 127.0.0.1 | websecurity x Login x +

localhost/LAB4/login.html

Login

Email

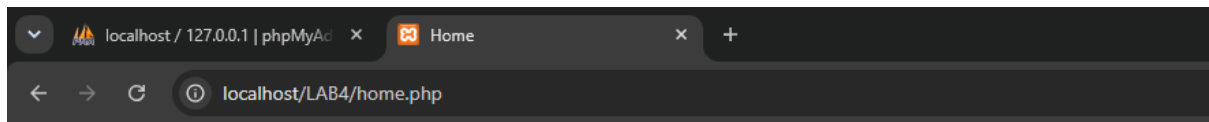
vedica@gmail.com

Password

.....

Login

[Register](#)



Welcome vedica

Role: user

[Update Profile](#) | [Logout](#)

Products

ID	Name	Price
1	Laptop	50000.00
2	Mouse	500.00
3	Keyboard	1000.00

3. Add client-side validation for login and registration. Check required fields, email format, and password length using HTML5/JavaScript.

- below are the client side validation for registration and login page
- if we leave the spaces empty, it asks to fill it out
- if the email isn't in correct form
- if password length is short or incorrect.

User Registration

Username:

Email:

❗ Please enter a part following '@': 'test@' is incomplete.

Role:

[Login](#)

Password:

❗ Please lengthen this text to 6 characters or more (you are currently using 3 characters).

[Login](#)

localhost / 127.0.0.1 / websecu... Register

localhost/LAB4/register.html

User Registration

Username:

Email:

Password:

Role:

[Login](#)

localhost / 127.0.0.1 / websecu... localhost/LAB4/login.php

localhost/LAB4/login.php

Incorrect Password

4. Create and manage session cookies and clear cookies or sessions on logout.

Logging to the user(test) and it re directs to the home page

localhost / 127.0.0.1 / websecu... Login

localhost/LAB4/login.html

Login

Email:

Password:

[Register](#)

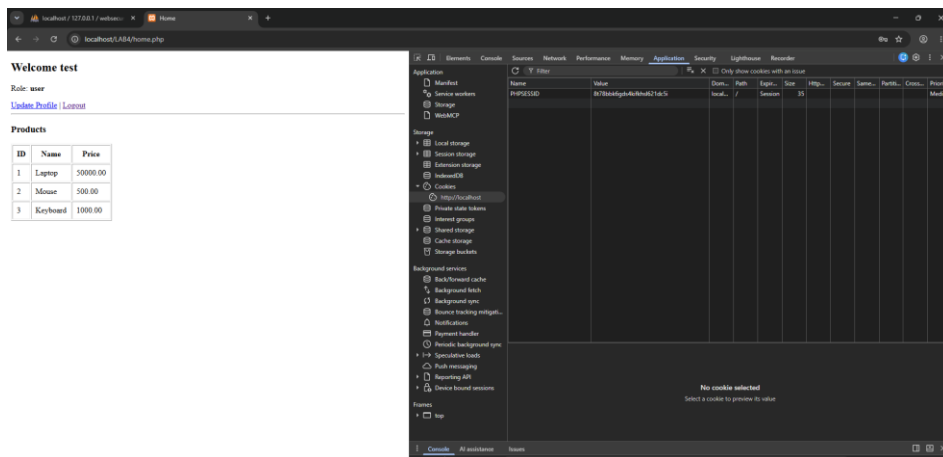
Application

Name	Value	Domain	Path	Expires	Size	HttpOnly	Secure	SameSite	HttpOnly	Cookie	Priority
No cookie selected Select a cookie to preview its value											

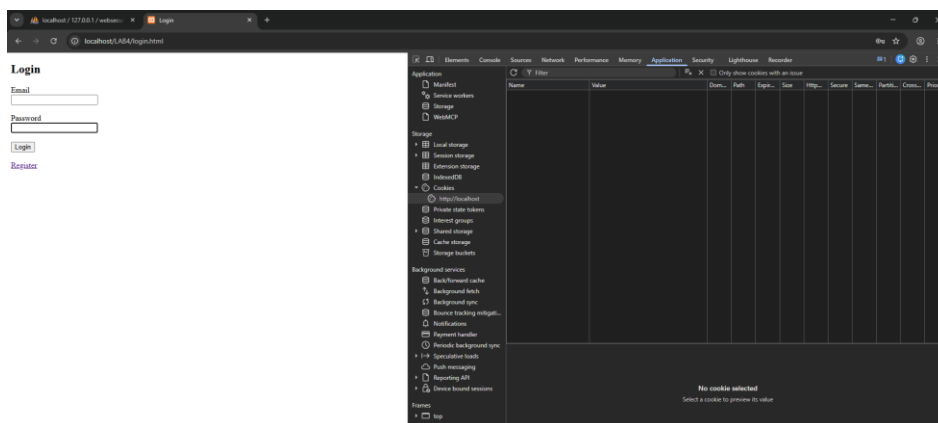
Console

test@gmail.com

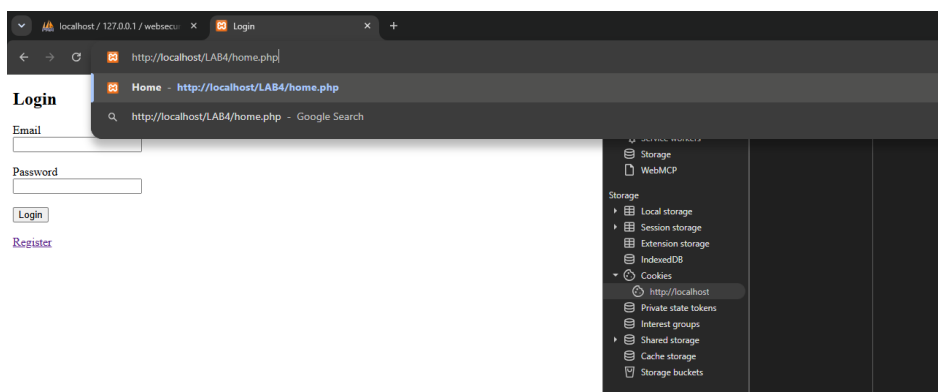
Now, the cookies are stored



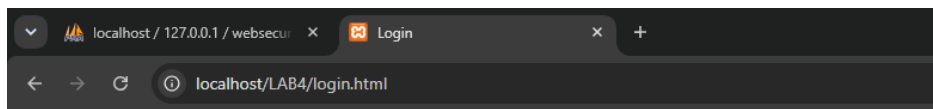
When we try to logout, the cookies are cleared.



When I try to redirect to the home page, it redirects to the login page stating that the cookies are cleared successfully.



- It redirects back to the login page.



Login

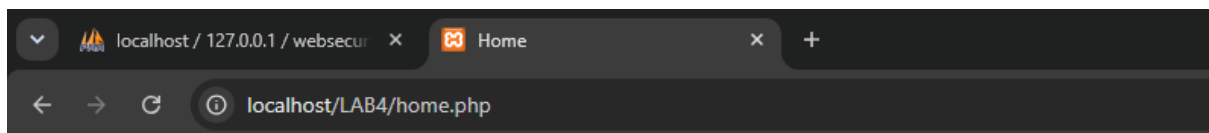
Email

Password

[Register](#)

5. Add a homepage (product page) having some sample data to be retrieved and displayed on successful login. Protect this route so it is accessible only with a valid session.

After logging in, the product page is successfully visited here.



Welcome vedica

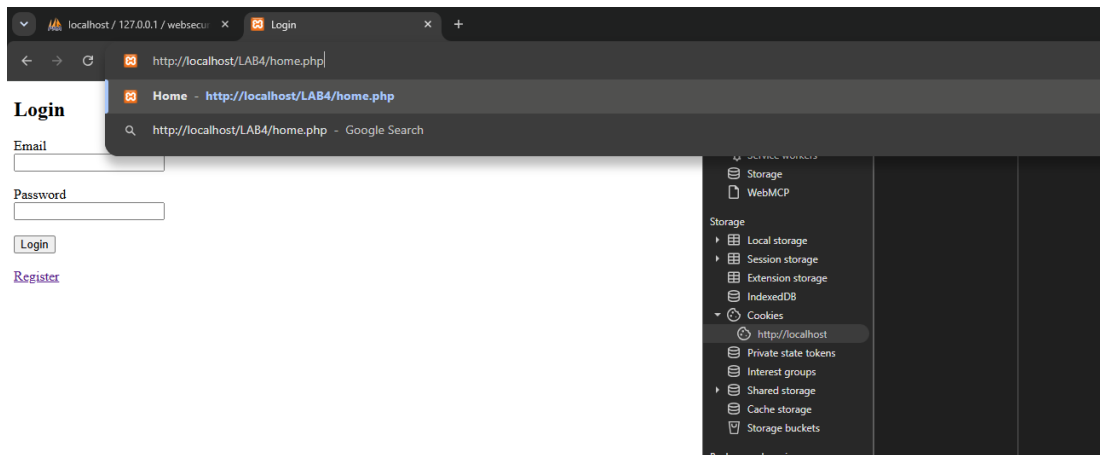
Role: **user**

[Update Profile](#) | [Logout](#)

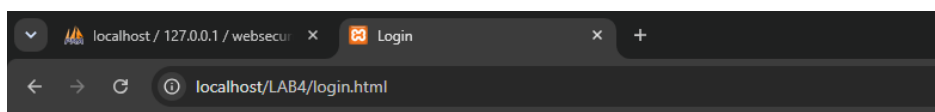
Products

ID	Name	Price
1	Laptop	50000.00
2	Mouse	500.00
3	Keyboard	1000.00

Once I log out and then try to access the home page directly in url – it'll redirect to the login page indicating tht the route is protected and can be accessed only



When I access this directly, its redirecting to the login page



Login

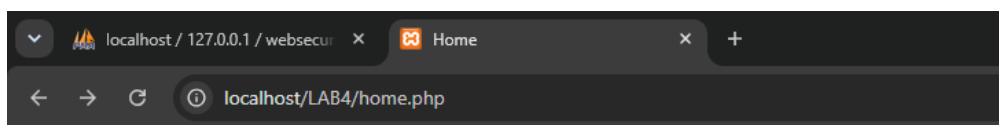
Email

Password

[Register](#)

6. Update username [update profile]. Allow the logged-in user to edit their username, identifying the user from the session rather than form data.

I'm logging in as test@gmail.com with the existing user name as **test**



Welcome test

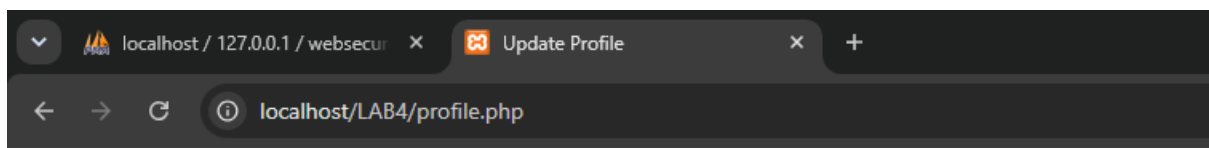
Role: **user**

[Update Profile](#) | [Logout](#)

Products

ID	Name	Price
1	Laptop	50000.00
2	Mouse	500.00
3	Keyboard	1000.00

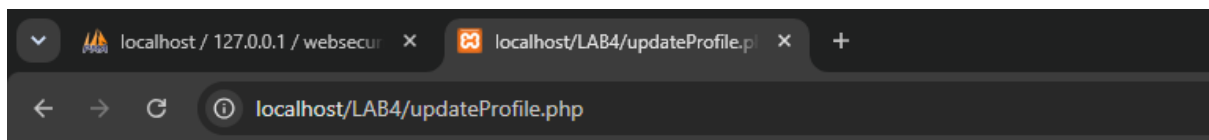
Now the new username is **testtt**



Update Username

New Username

[Back](#)



Username Updated Successfully.

[Go Home](#)

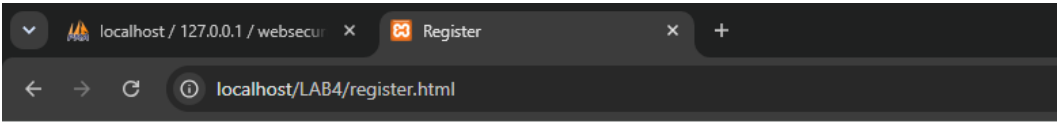
Extra options

				id	username	email	password	role
☐	Edit	Copy	Delete	1	vedica	vedica@gmail.com	\$2y\$10\$9EEFFleXy7OThhfWdPS.aeqYXxlrXdod0LVNOo5ooy...	user
☐	Edit	Copy	Delete	2	testtt	test@gmail.com	\$2y\$10\$kvqxiOkO1kkP92xJCpWMO.B2OyLFABMA0w28X.AM.r...	user

☐ Check all With selected: Edit Copy Delete Export

7. On registration, add a role option (admin, user) , or add, update remove product list access to only admin (RBAC). Show the entire database details after add/update/remove using Fetch API. Restrict at least one route to admin users only; other roles should receive a 403.

Registration as an *admin*



User Registration

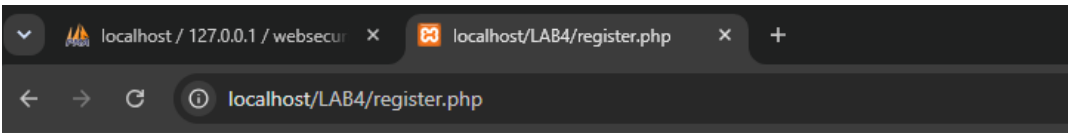
Username:

Email:

Password:

Role:

[Login](#)

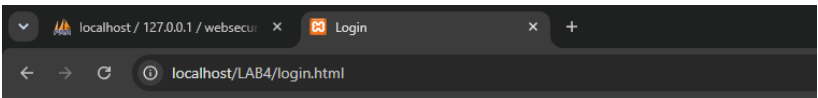


Registration Successful

[Login](#)

Extra options

				id	username	email	password	role
☐				1	vedica	vedica@gmail.com	\$2y\$10\$9EEFFleXy7OThhfWdPS.aeqYXlrrXdod0LVNOo5ooy...	user
☐				2	testtt	test@gmail.com	\$2y\$10\$kvqxiOkO1kkP92xJCpWMO.B2OyLFABMA0w28X.AM.r...	user
☐				3	admin	admin@gmail.com	\$2y\$10\$/UGDDFJYwcEA0ZSdLFJXAuO0sUDUhp4aYT.XIJLGI45...	admin

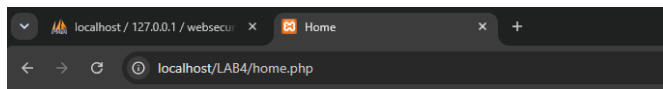


Login

Email

Password

[Register](#)



Welcome admin

Role: admin

[Update Profile](#) | [Logout](#) | [Admin Panel](#)

Products

ID	Name	Price
1	Laptop	50000.00
2	Mouse	500.00
3	Keyboard	1000.00

Admin can *ADD*

Admin Panel

Welcome: admin

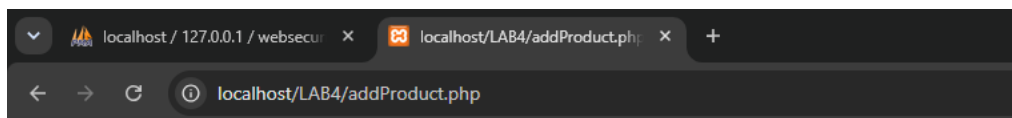
[Home](#) | [Logout](#)

Add Product

Product Name

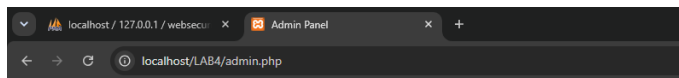
Price

Product Database



Product Added Successfully.

[Back to Admin Panel](#)



Admin Panel

Welcome: admin

[Home](#) | [Logout](#)

Add Product

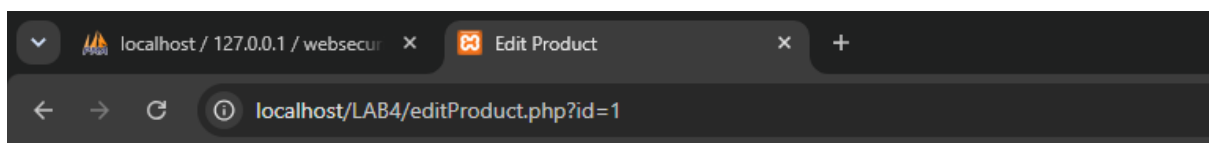
Product Name

Price

Product Database

ID	Name	Price	Update	Delete
1	Laptop	50000.00	Update	Delete
2	Mouse	500.00	Update	Delete
3	Keyboard	1000.00	Update	Delete
4	PC	262000.00	Update	Delete

Admin can **UPDATE**



Edit Product

Product Name

Price

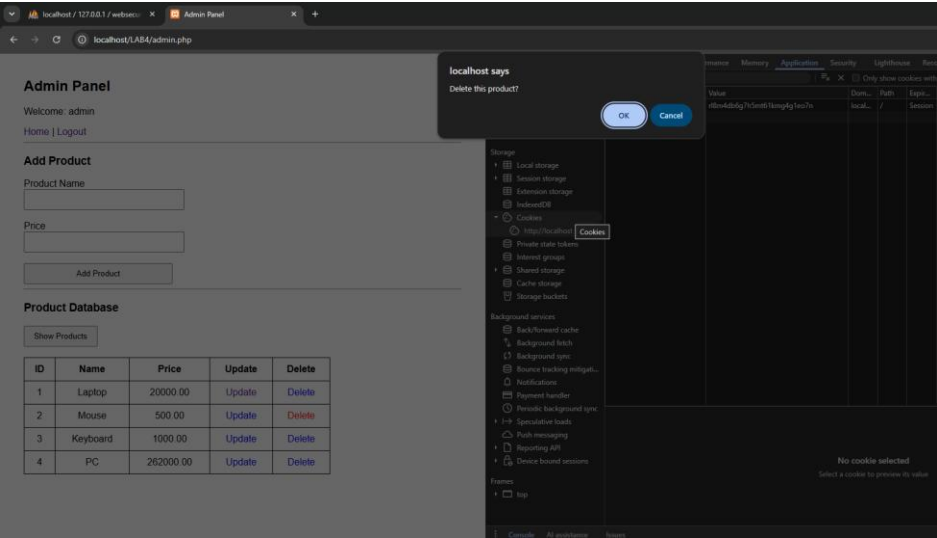
[Back](#)

Product Database

Show Products

ID	Name	Price	Update	Delete
1	Laptop	20000.00	Update	Delete
2	Mouse	500.00	Update	Delete
3	Keyboard	1000.00	Update	Delete
4	PC	262000.00	Update	Delete

Admin can **DELETE**

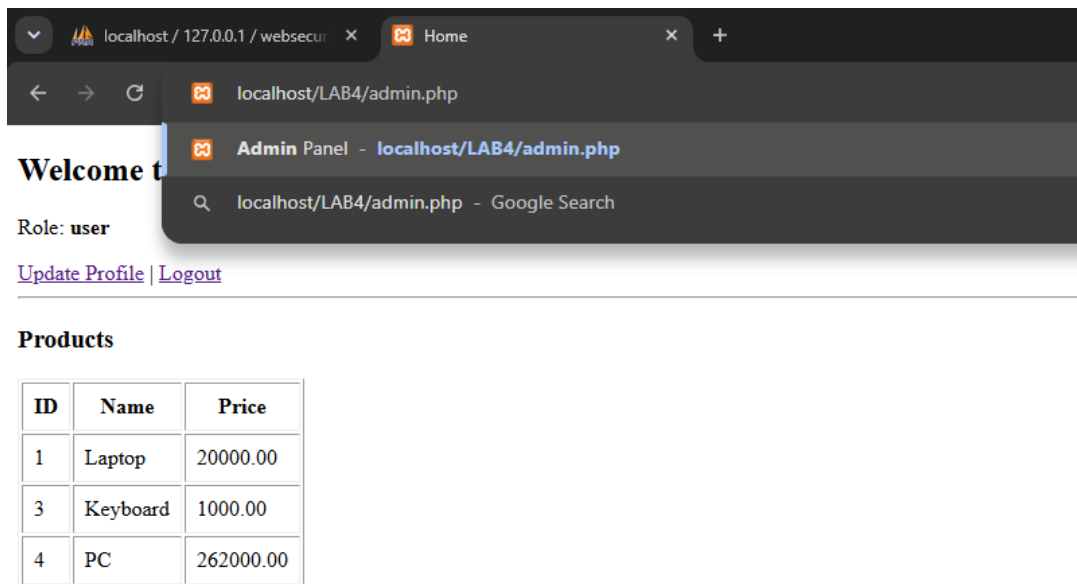


Product Database

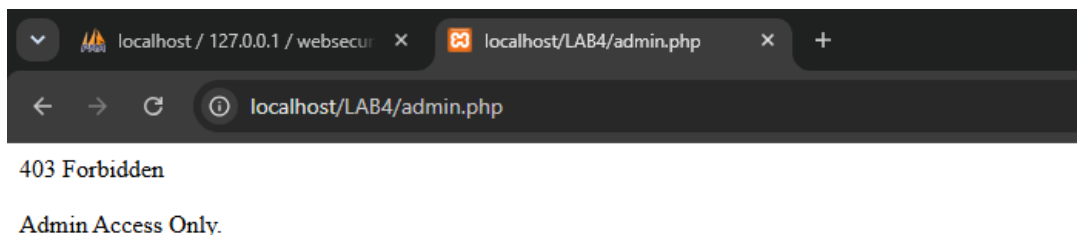
Show Products

ID	Name	Price	Update	Delete
1	Laptop	20000.00	Update	Delete
3	Keyboard	1000.00	Update	Delete
4	PC	262000.00	Update	Delete

Logged in as *testtt* user



We can't access to the admin page as a user



8. Add server-side validation for login and registration. Re-validate the same rules on the server and sanitize inputs.

Cmd line server side validations

```
C:\Users\cyberlab>curl -X POST http://localhost/LAB4/register.php -d "username=&email=&password=&role=user"
All fields required
C:\Users\cyberlab>curl -X POST http://localhost/LAB4/register.php -d "username=test&email=abc&password=password123&role=
user"
Invalid Email
C:\Users\cyberlab>curl -X POST http://localhost/LAB4/login.php -d "email=test@gmail.com&password=wrongpassword"
Incorrect Password
C:\Users\cyberlab>
```